

Integrated HR and Finance Compliance Platform

Overall System Architecture Design

AWS Hackathon Company Team Project

Version 1.0 | 25 September 2026

This design connects recruitment, employees and payroll, financial reporting preparation, compliance controls and audit evidence management into a traceable business process. It provides an engineering blueprint for a controlled MVP and a subsequent enterprise pilot.

Executive Summary

The proposed architecture centres on business domain boundaries and a traceable evidence chain. A unified portal provides the user interface. Modular Spring Boot services support recruitment, employee and payroll integration, financial evidence, control rules, approvals and AI analysis. An event bus, queues and workflow orchestration handle cross-system and long-running tasks. The initial objective is a demonstrable, reviewable and extensible compliance workflow. Existing payroll, ERP, statutory audit and Teams responsibilities remain with their respective systems and professionals.

The main architectural decision is to deliver the MVP as one deployable modular Spring Boot application, rather than immediately creating many microservices. Each domain still has explicit interfaces, data ownership and domain events. A module can become independently deployable when scale, team ownership or availability requirements justify it. This approach reduces operational complexity during the hackathon and pilot while preserving a path for later expansion.

1 Objectives, Scope and Architecture Decisions

1.1 Design Objectives

- Connect job advertisements, candidate processing, Teams interviews, hiring, employees, cost centres, payroll, financial evidence, rule checks, report drafts and approval decisions in a continuous, traceable process.
- Represent regulatory requirements and internal controls as versioned configuration with effective dates and approval by responsible owners, rather than fixed conditions scattered through business code.
- Allow AI to read only controlled case packages and produce drafts with source references. Authorised people retain responsibility for accounting judgments, hiring decisions, acceptance of exceptions, management confirmation and board governance.
- Make least privilege, data classification, retention controls, protection against evidence overwrites and independent audit logs default controls from the outset.

1.2 Scope and Non-Goals

Scope	Initial implementation	Outside the initial scope
Recruitment and fair consideration	Job requisitions, advertising evidence, candidates, scorecards, hiring decisions and FCF completeness reminders.	Unauthorised scraping or automated MyCareersFuture access. Automated rejection or analysis of emotion, faces or accents.
Teams interviews	Create, reschedule and cancel Teams calendar meetings through Microsoft Graph. Store the required meeting identifiers.	Default access to chats, recordings, transcripts or meeting attendance reports.
HR and payroll	Employee record references, positions, start dates, cost centres, controlled payroll integration and compliance reminders.	Replacing payroll systems, executing salary payments or automatically submitting CPF contributions.
Finance and audit preparation	Import and link general ledger records, invoices, payments, reconciliations, working papers and evidence. Run controls and prepare evidence packages.	Automatically changing the ledger, initiating payments, submitting XBRL or making external filings.
AI assistance	Summaries of anomalies, evidence citations, risk summaries, draft audit preparation reports and proposed follow-up tasks.	Statutory audit opinions, compliance assurance, automatic approvals or substitution for professional judgment.

1.3 Key Architecture Decisions

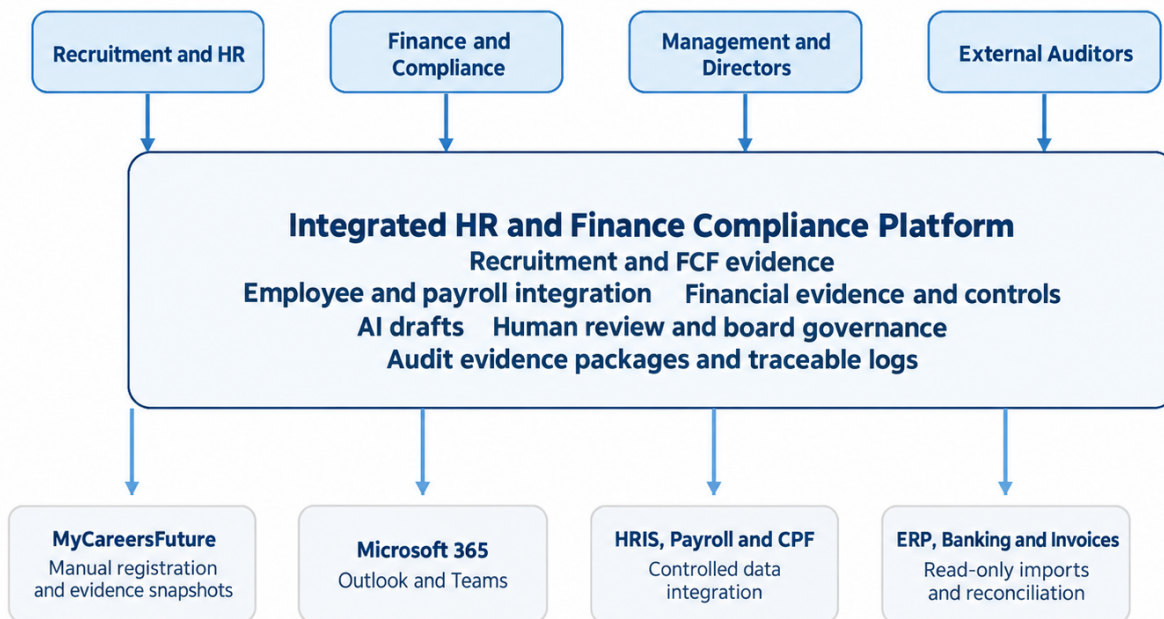
Decision	Recommended design	Rationale
Application structure	A Spring Boot modular monolith, separated by domain packages and interfaces. Later separation follows event boundaries.	Maintain delivery speed and simple debugging for the MVP. Avoid premature microservices.
Interaction model	Synchronous REST APIs handle user actions. Outbox, EventBridge, SQS and Step Functions handle asynchronous work and approvals.	Reliable transactions, loose coupling, controlled retries and auditability.
Systems of record	Recruitment, HR, payroll and finance retain their authoritative sources. The platform holds necessary copies, references and evidence versions.	Prevent the integrated platform from becoming an unverified master data source.
Data and evidence	Aurora PostgreSQL manages transactional state. S3 Versioning and Object Lock manage original evidence and final reports.	Separate transactional consistency from versioned evidence protected against overwriting.
AI controls	The rules engine runs deterministic checks first. AI explains, summarises and drafts. Every conclusion links to evidence.	Keep outputs explainable and reviewable. The LLM does not determine compliance or audit conclusions.

2 System Context and Logical Layers

The platform operates between enterprise HR, finance, compliance and Microsoft services. It coordinates cross-departmental workflows through minimised data, shared identifiers, control results, approval records and an evidence index. It does not need to replicate all business information. Teams continues to manage meetings and calendars. HRIS, payroll and ERP systems remain responsible for their native business records. The platform retains the necessary synchronised data, snapshots, references and traceable decisions.

System Context and Responsibilities

The platform stores traceable facts, control results, decisions and evidence. External systems retain their native responsibilities.



Data minimisation | Least privilege | Versioned evidence | AI drafts only | Human judgment

Figure 1 System context and responsibility boundaries

2.1 Logical Layers

Layer	Responsibilities	Key controls
Experience and access	React or an equivalent web portal, controlled candidate pages, and management and external audit data rooms.	SSO, MFA, session expiry, and records of devices and access origins.
API and application	BFF/API, domain modules, input validation, idempotency, authorisation, audit events and transactional Outbox.	JWT validation, RBAC with ABAC, request correlation IDs and rate limiting.

Layer	Responsibilities	Key controls
Workflow and events	Approvals, deadline reminders, asynchronous imports, Graph calls, file processing, retries and escalation.	EventBridge, SQS dead-letter queues, Step Functions, deduplication and controlled replay.
Data and evidence	Business transactions, source references, files, object versions, hashes, rule versions, logs and sealed reports.	Database isolation, S3 Versioning, KMS, retention and legal holds.
Governance and operations	Infrastructure, monitoring, keys, alerts, changes, backups, costs and security posture.	IaC, audit logs, least-privilege IAM, independent security accounts and runbooks.

2.2 Domain Module Boundaries

Module	Core responsibilities	Write access boundaries
Recruitment and FCF	Jobs, advertising evidence, candidates, applications, interviews, scorecards, hiring decisions and evidence packages.	Cannot copy complete candidate records into finance or issue offers automatically.
Teams integration adapter	Create, reschedule, cancel and reconcile calendar meetings. Associate necessary meeting IDs.	Cannot read organisation-wide calendars, chats, recordings or transcripts.
Employee and payroll integration	Employee IDs, positions, start dates, cost centres, payroll references, work passes and expiry reminders.	Cannot execute payroll or overwrite authoritative HRIS records.
Financial data and evidence	Import ledgers, invoices, payments, bank reconciliations, contracts and report working papers. Build the evidence index.	Cannot change the ledger, execute payments or alter original evidence versions.
Rules and risk	Rule versions, control runs, exceptions, risk severity, remediation, exceptions accepted by people and expiry dates.	The LLM cannot create or change rules on its own.
Approvals and reports	Task assignment, separation of duties, reviews, returns, authorisation, report versions and sealing.	Preparers cannot approve their own key reports.
AI analysis and model governance	Minimised case packages, controlled retrieval, drafts, model runs, prompts and evaluation versions.	AI has no production business write, payment, filing or approval authority.
Audit and privacy governance	Audit events, export records, retention, legal holds, privacy requests and proof of deletion.	Operations staff cannot use this module to read business data in plaintext.

3 Core Business Processes and State Machines

The following workflow is the focus of the MVP demonstration. At every stage, the system must show where the facts came from, which rule version was used, who reviewed the case and why it was approved or returned. Human actions create event records. Changes to key files, rules or reports automatically invalidate downstream approvals.

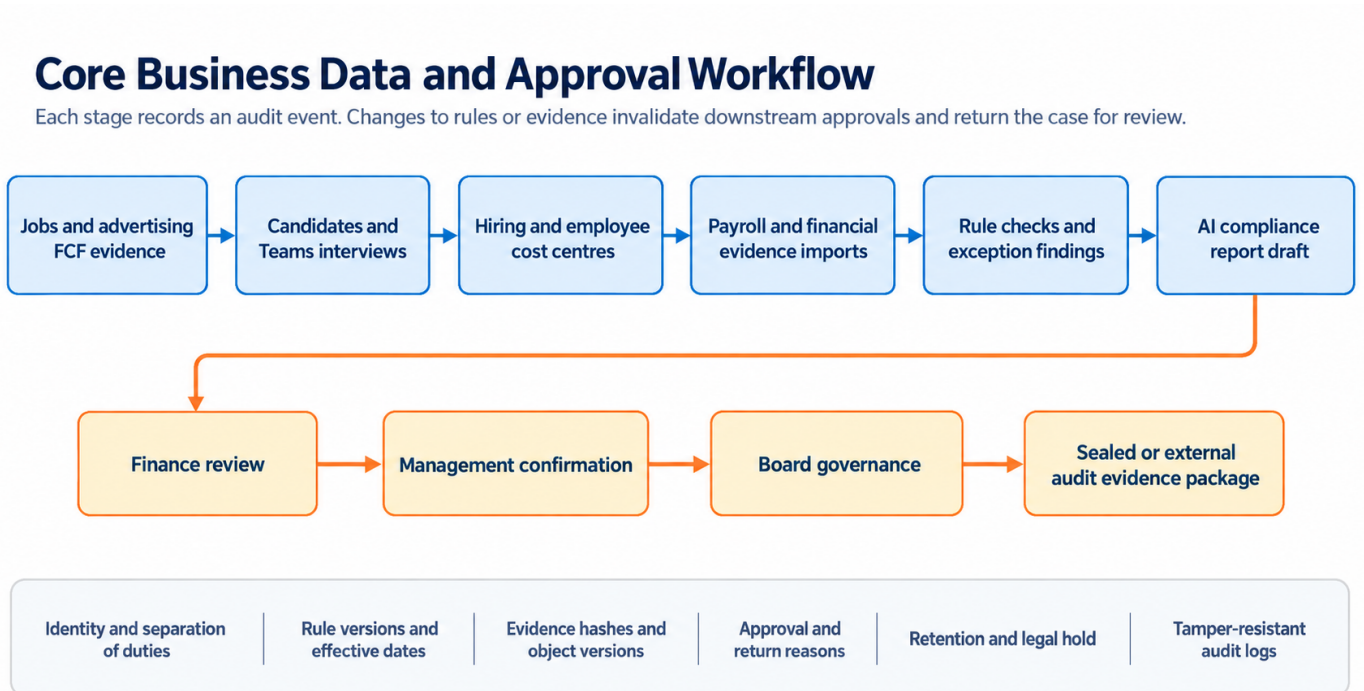


Figure 2 Core workflow from recruitment to financial reporting preparation and governance

3.1 Recruitment and Teams Interviews

- HR creates a JobRequisition and defines objective selection criteria directly relevant to the job, together with the legal entity and cost centre.
- The rules service assesses FCF applicability. HR records the MyCareersFuture advertisement ID, URL, start and end times, a snapshot of the advertisement text and the review record. The initial phase does not assume that a directly usable official API is available.
- After a recruiter selects interviewers and a time slot, the recruitment module creates an Interview and an InterviewScheduleRequested event. The Teams adapter uses the Microsoft Graph Calendar API to create an Outlook event with a Teams link in an authorised organiser calendar.
- Interviewers submit a structured Scorecard, which locks on submission. A correction must create a new version and record a reason. Historical scores cannot be silently overwritten.
- Before an offer, the system checks the advertising period, advertising evidence, scorecards, conflicts of interest and authorisation. Missing requirements move the case to ComplianceReviewRequired. A system pass cannot replace the final judgment of HR or compliance personnel.

- After OfferAccepted, only the employee ID, legal entity, position, start date, cost centre and necessary payroll reference pass to the employee and finance domains. The full CV, assessment scores, recordings and transcripts must not be copied.

3.2 Financial Controls and AI Audit Preparation

DRAFT -> DATA_VALIDATED -> AI_DRAFT_READY -> FINANCE_REVIEW
 -> REMEDIATION_PENDING -> MANAGEMENT_CONFIRMED -> BOARD_PACK_ISSUED
 -> BOARD_ACKNOWLEDGED / BOARD_REJECTED -> SEALED -> ARCHIVED

The financial import service receives authorised general ledger records, invoices, payments, bank reconciliations and payroll summaries. It first validates the source, structure, period, duplicates and completeness, then registers an EvidenceAsset and the object hash. The rules service performs reviewable controls, including missing evidence, duplicate payments, approvals outside delegated authority, period mismatches and separation of duties. AI may read a minimised case package and generate a draft with evidence links only after the input data and rule runs are complete.

Reports must clearly distinguish the AI draft, finance review, management confirmation, board governance and external audit opinion. Where statutory audit is required, an independent registered public accountant must obtain evidence and issue an opinion independently. The platform supplies an audit preparation package and a controlled read-only data room. [8, 9]

3.3 Events and Idempotency

Cross-module actions use a database transaction and the Outbox pattern. The business state and event awaiting publication are written in the same transaction. A publisher then sends the event to EventBridge, and consumers process it through SQS queues. This supports traceability and recovery during network failures, duplicate delivery or downstream unavailability. Event payloads contain only IDs, versions, hashes, classifications and references. They exclude CVs, bank account numbers, payroll content and original supporting documents.

Example event	Producer	Consumers and controls
InterviewScheduleRequested	Recruitment module	Teams adapter. Use interviewId with revision for idempotent calendar meeting creation.
EvidenceRegistered	Import and evidence module	Rules service and audit log. Retain the object version and SHA-256 hash.
ControlRunCompleted	Rules service	Risk and approval modules. High-risk findings automatically create manual tasks.
AIDraftCreated	AI analysis module	Finance review module. Record the model, prompt, Guardrail and input manifest hash.
BoardDecisionRecorded	Approval module	Report and audit modules. Seal the decision, attachments and approval trail.

4 AWS Reference Deployment Architecture

The production reference architecture places business compute, data, evidence, AI and security logs within controlled AWS boundaries. The MVP can use one application account with logical separation through distinct IAM roles, KMS keys, S3 buckets, VPC subnets and data classifications. An enterprise pilot can then separate Security and Log Archive, Production Application, Finance Evidence, AI Processing and Audit Exchange into dedicated accounts. The six pillars of the AWS Well-Architected Framework provide a baseline for architectural review. [10]

AWS Reference Deployment Architecture

Singapore is the proposed primary data region. Verify service and model availability before deployment.

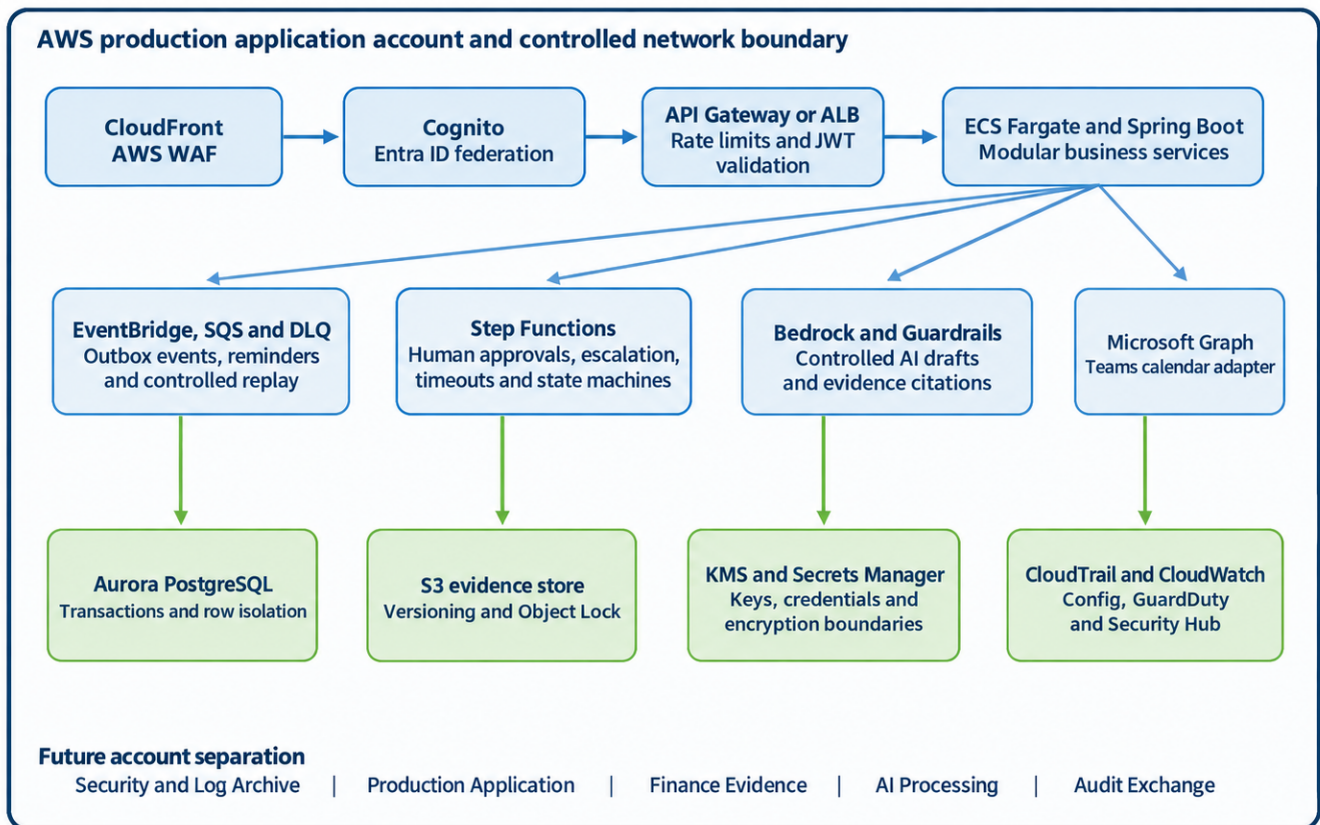


Figure 3 AWS production reference deployment architecture

4.1 AWS Service Mapping

Capability	Recommended AWS services	Implementation considerations
Web and edge protection	CloudFront and AWS WAF	Distribute static frontend assets through CloudFront. Use WAF for common web attacks, rate policies and origin policies.
Enterprise identity	Amazon Cognito and Microsoft Entra ID through OIDC	Cognito standardises tokens and attribute mapping. The application authorises access using claims such as tenant, legal entity, role and data classification. [11]
API and business compute	API Gateway or ALB, ECS Fargate and Spring Boot	Run services in private subnets. Use health checks, automatic scaling and request correlation IDs.
Transactional data	Aurora PostgreSQL	Store business master data, approvals, rules, Outbox records and references. Isolate tenants and legal entities.
Events and workflows	EventBridge, SQS, DLQ, Step Functions and Scheduler	Decouple modules, retry reliably, support manual intervention, schedule reminders and manage approval state machines. [12]
Files and evidence	Amazon S3, Versioning, Object Lock and AWS Backup	Version originals and final reports. Record hashes and lock retention. Object Lock supports WORM retention and legal holds. [13]
Text extraction and AI	Textract, Amazon Bedrock and Bedrock Guardrails	Textract extracts text only. Bedrock receives a minimised case package. Guardrails filter inputs and outputs, while the application retains field-level controls. [14]
Keys and secrets	AWS KMS and Secrets Manager	Use separate customer-managed keys for data domains. Keep Graph tokens and connection credentials out of code and logs. [15]
Audit and security	CloudTrail, CloudWatch, Config, GuardDuty, Security Hub and Macie	Record management-plane and object access, unusual access, configuration drift, security findings and PII risks.

4.2 Network and Account Topology

- Public entry points are limited to CloudFront, WAF and the necessary API endpoints. Spring Boot services, databases, queue access and management endpoints remain within private subnets.
- Use VPC endpoints or PrivateLink for AWS services where available. Calls to Microsoft Graph and approved enterprise systems pass through controlled NAT or proxy egress, with the destination and call outcome recorded.
- Production, test and development use separate accounts or, at minimum, separate environments, KMS keys, databases, buckets and identity roles. Non-production environments use synthetic or de-identified data by default.

- Singapore, ap-southeast-1, is the proposed primary data residency region. Before deployment, the DPO, legal and cloud governance teams must assess the actual regions and cross-border flows of Bedrock models, backups and third-party services.

4.3 Availability and Recovery Objectives

Scenario	MVP recommendation	Enterprise pilot recommendation
Application failure	Replace stateless Fargate tasks. Retry key operations from queues.	Deploy across Availability Zones, use automatic scaling, maintain runbooks and conduct exercises.
Database recovery	Daily backups and point-in-time recovery exercises. Initial proposed targets: RPO of 24 hours and RTO of 8 hours.	Aurora across multiple Availability Zones and cross-account backups. Define stricter RPO and RTO targets according to business impact.
Evidence protection	S3 Versioning, a separate backup plan and export manifests.	Object Lock, cross-account copies, legal holds and exercises that verify evidence recovery.
Third-party outage	Queue retries, followed by ManualSchedulingRequired or ManualImportRequired when necessary.	Circuit breakers, degraded operating modes, reconciliation jobs, supplier SLAs and incident notifications.

5 Data Architecture and Master Data Model

The data design follows a system-of-record and reference approach. The platform creates its own aggregates, workflow states, control results, approval records and evidence index for cross-domain processes. It must not treat an unverified synchronised copy as the authoritative payroll or general ledger record. Every key object has a globally unique immutable ID, a version, a legal entity, a data classification, a creator and associated audit events.

5.1 Core Entities

Entity	Key fields	Ownership and relationships
JobRequisition	requisitionId, legalEntity, jobCode, costCentre, selection criteria version and status.	Recruitment aggregate root linked to advertisements, applications, interviews and decisions.
JobAdvertisement	source, adId, URL, advertisement text hash, start and end times, and reviewer.	Stores FCF evidence. Initially registered manually or through authorised imports.
Candidate and Application	candidateId, minimum contact details, privacy notice and application status.	Separates the candidate profile from each application to support purpose limitation.
Interview and Scorecard	interviewId, eventId, interviewer, scorecard template version, submission and lock status.	Teams integration retains only necessary meeting references. Submitted scorecards are versioned.
Employee and CostAllocation	employeeId, legalEntity, position, startDate, costCentre and payroll record reference.	Linked only after hiring. Interview records are not copied.
JournalEntry and EvidenceAsset	sourceSystemId, period, amount, objectVersionId, SHA-256 and retention.	Finance owns imported records and evidence references. Original versions cannot be overwritten.
ControlRule and Finding	ruleVersion, effectiveDate, inputSet, severity, evidenceRefs and remediation.	The rules domain retains deterministic findings and human-approved exceptions.
Report and ApprovalCase	reportVersion, claimEvidence, status, decision, actor and timestamp.	Reports and approvals have separate versions. Sealing the final report generates a manifest.
ModelRun and AuditEvent	model, promptVersion, guardrailVersion, inputHash, outputHash and correlationId.	Model governance and audit domains retain reviewable execution records without unnecessary source content.

5.2 Shared Identifiers and Data Classification

Classification	Examples	Handling rules
General business	Job identifiers, cost centres, rule versions and aggregate states.	Read access follows role and legal entity. Data may support operational analytics.
Personal data	Candidate contact details, employee records and Teams metadata.	Purpose limitation, minimisation, encryption, retention periods, and access and correction processes.
Highly sensitive	Payroll, banking details, NRIC or equivalent identification, contracts and financial evidence.	Separate KMS keys by domain, field masking and fine-grained ABAC. Exclude this content from event payloads and general logs.
Audit and governance	Control results, approvals, export records, report manifests and object hashes.	Append-only records, version protection, controlled retention and read-only audit access.

5.3 Audit Event Contract

Every auditable action writes an append-only AuditEvent. The event records the actor, target and a change summary or content hash, rather than copying sensitive source content. Audit events are stored separately from business events. A correlationId connects the initiating user action, asynchronous work, Graph calls and the final approval.

eventId | schemaVersion | tenantId | legalEntityId | aggregateId | correlationId
causationId | actorRef | action | occurredAt | classification | evidenceRefs | idempotencyKey

6 Integration and API Design

6.1 API Principles

- Expose versioned REST APIs to the frontend, such as /api/v1/requisitions, /api/v1/interviews, /api/v1/evidence, /api/v1/reports and /api/v1/approvals. The server must calculate resource scope from token claims and business membership. A scope supplied by the frontend does not authorise access by itself.
- Support idempotency keys for all create and update requests. For imports and third-party callbacks, retain sourceSystem, sourceRecordId, sourceVersion and the received timestamp to prevent duplicate records.
- Use short-lived presigned S3 upload URLs for large files. After upload, scan for malware and validate the MIME type, hash and classification before registering the file as an EvidenceAsset.
- Handle external system failures through retries, backoff, dead-letter queues and manual tasks. Do not wait indefinitely in the business request thread.

6.2 Microsoft Teams and Graph Integration

The initial design uses calendar-backed Teams meetings. The recruitment service writes the interview and an Outbox event. An integration adapter uses the authorised recruitment coordinator's delegated permissions to call Microsoft Graph Calendar APIs and create, update, read or cancel Outlook calendar events. Compared with a standalone onlineMeeting, this approach better supports calendar invitations, rescheduling, cancellation and subsequent reconciliation. [6]

Operation	Recommended call	Stored data and restrictions
Create	POST /me/events with isOnlineMeeting set to true.	Retain eventId, iCalUid, organiser, status and an encrypted reference to the join link.
Reschedule	PATCH /me/events/{eventId}.	Use interviewId with revision as an idempotency reference. Record the change in the audit trail.
Cancel	POST /me/events/{eventId}/cancel.	Synchronise the Interview state and record the reason. Do not store invitation content in platform logs.
Reconcile	GET the event, or later use delta queries or webhooks.	Detect manual Outlook changes and create confirmation tasks. Do not silently overwrite them.

Initially, restrict access to delegated Calendars.ReadWrite. Do not request organisation-wide calendar access or permissions to read meeting transcripts, recordings or chats. If a dedicated recruitment service account is introduced later, obtain Entra administrator approval, limit accessible mailboxes and enforce least privilege through application access policies.

6.3 HRIS, ERP, CPF and External Data Integration

System	Integration mode	Initial controls
HRIS and payroll	REST, SFTP batches or controlled CSV imports.	Accept only approved field mappings. Synchronise employees, positions, cost centres and payroll references without overwriting authoritative records.
ERP and banking data	Read-only APIs, batch files or a secure landing area.	Source deduplication, period validation, reconciliation status, object hashes, error isolation and human review.
CPF	Initially, rule checks, deadline reminders and follow-up tasks.	Before formal submissions, complete supplier authorisation, interface assessment, UAT and separation-of-duties design.
MyCareersFuture	Advertisement ID, URL, snapshot and manual review registration.	No unauthorised web scraping. Assess an official interface only after obtaining authorisation.

7 Identity, Access, Privacy and Security

7.1 Identity and Authorisation Model

Employees sign in through Microsoft Entra ID single sign-on. Amazon Cognito converts the external OIDC identity into standard application tokens and maps the required attributes. Application authorisation combines RBAC and ABAC. Roles determine permitted actions, while attributes constrain the tenant, legal entity, cost centre, job, case and data classification to which those actions apply. Cognito supports OIDC federation, user attribute mapping and token issuance to the application. [11]

Role	Permitted actions	Prohibited actions
Recruiter	Create jobs, candidates, interviews and advertising evidence. Trigger Teams scheduling.	Approve their own FCF exceptions or read financial audit packages.
Interviewer and Hiring Manager	Read necessary information for assigned jobs and submit assessments or recommendations.	Read unrelated jobs, issue offers or change advertising evidence.
Finance Preparer	Import data, explain differences and generate financial or AI drafts.	Approve their own reports or delete evidence.
Controller and CFO	Review evidence, confirm exceptions, provide management confirmation and approve rule changes.	Bypass board governance or clear audit logs.
Directors and Audit Committee	Review board packs, material risks and remediation plans, and record decisions.	Alter original evidence, rules or models.
External Auditor	Use a read-only audit data room and make information requests within defined case and time limits.	Modify business facts, internal approvals or payments.
DPO and Platform Operations	The DPO reviews privacy governance. Operations manages infrastructure availability.	The DPO does not make financial judgments. Operations has no default access to business plaintext.

7.2 Data Protection and Retention

Data category	Initial retention policy	Key controls
Interview records, assessments and hiring decisions	Retain for at least one year, or longer under applicable law, investigations or company policy.	Retain structured records and decision reasons. Do not collect original recordings or transcripts by default.
CVs of unsuccessful candidates	Set retention according to the notified business or legal purpose. Delete or anonymise at expiry.	Talent pools, reuse across jobs and model training require separate consideration of notice and authorisation.

Data category	Initial retention policy	Key controls
Employee and payroll records	Apply the separate employee and payroll retention policies.	Recruitment retains only necessary links. Payroll and banking access remain separated by domain.
Financial books, supporting records and reports	Retain under applicable accounting record requirements and company policy.	Versions, hashes, S3 Object Lock, legal holds and the external audit data room.
AI traces and security logs	Set a shorter approved period based on risk, traceability needs and data minimisation.	Do not retain sensitive inputs indefinitely. Prefer hashes, references and necessary explanations.

- Deletion processes must support legal holds, scheduled expiry, failure alerts and proof of deletion. Deleting a platform record does not automatically delete copies held in Microsoft 365, backups or under supplier retention policies.
- The actual cross-border processing paths for candidate data, employee records, payroll, financial evidence and AI inputs and outputs must be documented. The DPO and legal team must confirm comparable protection under the PDPA and the relevant supplier terms.

7.3 Technical Security Controls

- Separate KMS keys for HR personally identifiable information, financial evidence, audit logs and AI traces. Separate KMS key administration from decryption permissions. Development roles must not administer production keys.
- Use Secrets Manager for database credentials, Graph credentials and other integration secrets. Never expose tokens in source code, CI logs, frontend local storage, audit events or exception stack traces.
- Use S3 object tags, bucket policies, access points, versioning and presigned URLs. Every EvidenceAsset reference must retain both the object version and its hash.
- Use AWS Organizations SCPs, IAM permission boundaries and CloudTrail protection policies to prevent disabling logs, deleting evidence, weakening Object Lock or deploying sensitive data services in unapproved regions.
- Emergency access requires MFA, short-lived authorisation, a ticket, immediate alerts and an independent retrospective review. It must not become a permanent administrative route around the workflow.

8 AI Compliance and Audit Preparation Architecture

The AI module produces an AI-assisted draft report for financial compliance and audit preparation. It may identify, summarise, explain and draft. It may not post accounting entries, make payments, alter original evidence, approve transactions, submit filings or claim to have completed a statutory audit. Authorised personnel and independent professionals retain their respective responsibilities for final accounting judgments, management confirmation, board authorisation and external audit opinions.

8.1 Controlled AI Data Flow

- Select an authorised case and construct a minimised Evidence Pack according to the legal entity, reporting period, role and data classification.
- Place extracted document text, rule results and metadata in a controlled retrieval layer. Mask, tokenise or exclude sensitive fields under policy before they reach the model.
- Send the fixed prompt template, rule version, evidence excerpts and a bounded question to an approved Bedrock model. Apply the approved Guardrail during the call.
- Validate model output against its JSON schema, evidence citation completeness, sensitive information scans and deterministic policies. Mark every unsupported assertion for human review.
- Send the AI draft to Finance Review, followed by management confirmation, board governance and, where required, an external audit data room. Any change to inputs, rules, evidence or the draft creates a new version and returns the related approvals for review.

8.2 Model Run Records and Release Governance

Control area	Required records	Release gate
Each inference	Model and region, model version, prompt template, Guardrail, knowledge base snapshot, input manifest hash, output hash, and whether the result was accepted or overturned.	Output must include evidence references, rule versions and risk status.
Model or prompt change	Test set, unsupported assertion rate, human override rate, bias and hallucination results, owner and rollback version.	Approval by the technical lead and CFO or compliance owner according to risk level.
Knowledge base or rule change	Source, reviewer, effective date, affected cases and the reason for the change.	Do not overwrite earlier versions. Historical reports retain the versions they used.
High-risk matters	Related-party transactions, material differences, missing evidence, unusual payments and inadequate source data.	Mandatory escalation to at least two different authorised people. AI cannot close the matter automatically.

Amazon Bedrock Guardrails can support content filtering, denied topics, sensitive information filtering and prompt-attack protection. They do not replace application-level field controls for data loss prevention, minimised inputs, output schemas, authorisation or human review. [14]

8.3 AI Access Boundaries

- The AI runtime role may read only de-identified input buckets, invoke approved models, write to the draft bucket and update ModelRun records. It must not receive production write access to Aurora, payment or filing API access, permission to delete original evidence, or general administrative privileges.
- Treat uploaded files, retrieval results and user input as untrusted content. Text within them must not change system instructions, trigger external tools, expand the data scope or bypass approval.
- Model administrators may manage tests, versions and evaluations, but have no default access to full production financial records. Production debugging uses de-identified samples, audit oversight and authorisation that expires.

9 DevSecOps, Observability and Operational Governance

9.1 Environments and Delivery Pipeline

Stage	Key activities	Release gate
Development	Synthetic data in local and development accounts. Unit tests, contract tests and static scanning.	No high-severity dependencies or plaintext secrets. Database migrations support rollback.
Testing and UAT	End-to-end workflows, a Graph sandbox or controlled tenant, permission matrices, negative tests and evidence export validation.	Business owners confirm key acceptance scenarios. The DPO confirms the personal data processing design.
Production	IaC deployment, blue-green or rolling updates, database migrations, health checks, change records and monitoring.	Security review, backup verification, alert routing, runbooks and a rollback plan.
Ongoing operation	Periodic reviews of rules, models, retention and connectors. Monitor costs, performance, errors and unusual access.	Monthly control reports and reviews of significant incidents.

- Manage infrastructure through IaC tools such as Terraform or AWS CDK. Review changes in code and promote them through environments. Do not allow permanent, untraceable configuration changes in the production console.
- Application logs use correlationId, requestId, actorRef, tenantId and aggregateId. Do not log personal data, tokens, meeting links, payroll content, bank details or complete prompt inputs.
- Monitor risks awaiting review, failed controls, import delays, overdue approvals, Graph retries, unsupported AI assertions and abnormal access.

9.2 Operational Alerts and Human Response

Signal	Automatic response	Human responsibility
Failed evidence import or malware scan alert	Quarantine the file, stop downstream processing and create a task.	The data owner confirms the source or resubmits the file.
Graph meeting creation failure	Retry through SQS while retaining the idempotency key. After the threshold, use ManualSchedulingRequired.	The recruiter arranges the meeting manually and records the reason.
High-risk control finding	Create a Finding and block normal progression of the related report or offer.	The Controller, HR or compliance personnel review, remediate or accept the risk.

Signal	Automatic response	Human responsibility
Unsupported AI output or Guardrail trigger	Reject or flag the draft and retain minimal debugging metadata.	The finance reviewer supplies evidence or adjusts the controlled input.
Unusual downloads or privilege escalation	Raise an alert, temporarily suspend access and retain logs.	Security and the DPO follow the incident response process.

10 Implementation Roadmap and Acceptance Criteria

10.1 Proposed Implementation Roadmap

Phase	Delivery focus	Exit criteria
Hackathon MVP	Jobs, advertising evidence, candidates, simulated Teams scheduling or controlled Graph integration, scorecards, employee cost centres, sample financial evidence, rule checks, AI drafts, approvals and evidence packages.	Demonstrate the full process from job advertisement to board pack. Show the source, rule and human responsibility behind each conclusion.
Controlled pilot	One legal entity or department, one HRIS or payroll source, one financial import source and a real controlled Entra and Teams tenant.	Pass permission matrix, retention, backup, import reconciliation, UAT and exception handling checks.
Enterprise expansion	Separate high-load modules, integrate ERP, establish security governance across accounts, and add external audit data rooms, metrics and operational reports.	Pass operational readiness reviews by security, the DPO, finance, legal and the governance committee.
Optional advanced capabilities	Approved transcription, knowledge bases, XBRL filing preparation, CPF or other official interfaces.	Explicit authorisation, demonstrated need, permission boundaries, testing and sign-off by the responsible professional.

10.2 MVP Acceptance Scenarios

- After a recruitment coordinator registers advertising evidence for an applicable job, the system calculates offerEligibleAt. An insufficient advertising period or incomplete evidence prevents normal progression of the offer workflow and creates a compliance task.
- A recruiter creates a Teams calendar meeting with delegated permissions. Repeated clicks do not create a duplicate meeting. Rescheduling and cancellation remain traceable in the platform audit trail.
- An interviewer cannot silently change a submitted scorecard. When the hiring manager proposes a hiring decision, the system displays the scores, job-related reasons, advertising evidence and authorisation status.
- After hiring, the finance module receives only the employee ID, legal entity, position, start date, cost centre and a controlled payroll reference. It cannot access the CV or interview assessments.

- After financial data import, the rules service identifies missing evidence or unusual payments. The AI draft provides an evidence reference, rule version and human-judgment indicator for each finding.
- A finance preparer cannot approve their own report. Once the board pack is sealed, any change creates a new version and preserves the original version, differences and reason.
- The external audit data room provides authorised auditors with read-only evidence for specified cases and periods. All access and exports appear in the audit log.
- When Graph, ERP or AI service failures are simulated, the system shows the business status and either retries or creates a manual task. Business facts, events and evidence references must not be lost.

10.3 Architecture Risks and Tradeoffs

Risk	Architecture response	Required business confirmation
Premature service separation	Keep the MVP as a modular monolith with explicit event boundaries. Validate workflows and responsibilities first.	Future team size, SLAs and independent deployment requirements.
Spread of sensitive data	Domain-specific data models, ABAC, minimal fields, encryption and event payloads without sensitive content.	Processing purposes, retention periods, cross-border transfers and supplier terms.
Misleading or unsupported AI conclusions	Deterministic rules first, evidence citations, output schemas, Guardrails, human review and quality metrics.	Risk thresholds, approval levels and responsibility for professional judgment.
Unreliable external integrations	Adapters, queues, idempotency, dead-letter queues, reconciliation and manual fallback.	Formal API authorisation, tenant policies and supplier SLAs.
Regulatory or rule changes	Version rules, assign effective dates, require approval and support rollback. Avoid hardcoding requirements.	Legal, DPO, HR and finance confirmation of applicable obligations.

11 Architecture Conclusion

The proposed modular enterprise application connects HR and finance through a controlled compliance workflow while preserving their separate data responsibilities. Shared identifiers, controlled integration, deterministic rules, workflows driven by events, versioned evidence, separation of duties and human governance connect recruitment, employee costs, financial reporting preparation and audit evidence in one traceable process.

Spring Boot and AWS managed services offer a practical basis for delivery, reliability and future expansion. AI produces drafts, while finance personnel, management, directors and independent auditors retain their respective final judgments and responsibilities. Before operational deployment, a controlled pilot should validate data sources, permissions, retention, cross-border processing, model governance, external interface authorisation and company-specific governance templates.

Appendix A Glossary

Term	Meaning
ABAC	Attribute-based access control. In addition to roles, it uses legal entity, cost centre, case, job membership and data classification to determine whether access is allowed.
Outbox	A pattern that writes business state and events awaiting publication in one database transaction, then reliably publishes the events in the background.
EvidenceAsset	An evidence record with its source, object version, hash, classification, retention and related business object.
Legal hold	A preservation status that suspends automatic deletion because of an investigation, dispute or legal obligation.
FCF	Fair Consideration Framework. The platform provides rules, evidence and reminders. Authorised people make the final applicability assessment.
WORM	Write Once Read Many. A storage control that prevents a particular version from being overwritten or deleted during its retention period.

Appendix B Key References

- [1] Ministry of Manpower. Fair Consideration Framework and candidate consideration guidance.
<https://www.mom.gov.sg/employment-practices/fair-consideration-framework>
- [2] Ministry of Manpower. Employment records.
<https://www.mom.gov.sg/employment-practices/employment-records>
- [3] Ministry of Manpower. Itemised pay slips.
<https://www.mom.gov.sg/employment-practices/salary/itemised-payslips>
- [4] CPF Board. Making CPF contributions.
<https://www.cpf.gov.sg/employer/making-cpf-contributions>
- [5] ACRA. Company directors duties and key obligations.
<https://www.acra.gov.sg/manage/companies/legal-requirements-common-offences/directors-duties/>
- [6] Microsoft Learn. Choose an API in Microsoft Graph to create and join online meetings.
<https://learn.microsoft.com/en-us/graph/choose-online-meeting-api>
- [7] PDPC. Data Protection Obligations.
<https://www.pdpc.gov.sg/data-protection-obligations>
- [8] ISCA. Singapore Standards on Auditing.
[https://www.isca.org.sg/standards-guidance/audit-assurance/standards-and-guidance/singapore-standards-on-auditing-\(ssas\)](https://www.isca.org.sg/standards-guidance/audit-assurance/standards-and-guidance/singapore-standards-on-auditing-(ssas))
- [9] ACRA. Requirements and eligibility for public accountants.
<https://www.acra.gov.sg/register/public-accountant/requirements-eligibility/>
- [10] AWS Well Architected Framework.
<https://docs.aws.amazon.com/wellarchitected/latest/framework/definitions.html>
- [11] Amazon Cognito. Using OIDC identity providers with a user pool.
<https://docs.aws.amazon.com/cognito/latest/developerguide/cognito-user-pools-oidc-idp.html>
- [12] Amazon EventBridge Documentation.
<https://docs.aws.amazon.com/eventbridge/>
- [13] Amazon S3. Locking objects with Object Lock.
<https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html>
- [14] Amazon Bedrock. How Amazon Bedrock Guardrails works.
<https://docs.aws.amazon.com/bedrock/latest/userguide/guardrails-how.html>
- [15] AWS Secrets Manager. Secret encryption and decryption.
<https://docs.aws.amazon.com/secretsmanager/latest/userguide/security-encryption.html>

This design supports system planning, competition demonstrations and controlled pilot discussions. It does not constitute legal, tax, work pass, accounting or audit advice. Before operational deployment, corporate legal counsel, the DPO, finance leadership, information security teams and qualified professionals should confirm the applicable obligations and company-specific governance requirements.